

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Ферма брутфорса MSSQL/RDP на bulletproof-хостинге zerolimit-servers.cool

MSSQL Brute-force • RDP Bruteforce • Bulletproof Hosting • C2 Panel

Параметр	Значение
Дата анализа	27 мая 2026
Классификация	Credential Access / Brute-force Infrastructure
Уровень угрозы	ВЫСОКИЙ
Панель управления	194.113.39.2:8443 — TLS O=MSSQL Panel (уникальный сертификат)
Размер фермы	10 MSSQL-ботов (194.113.39.0/24) + 5 RDP-ботов (185.218.138.0/24)
Оператор	Vlad Cojuhari — zerolimit-servers.cool — AS205997
Анонс подсети	AS206378 (FOP Dmytro Nedilskyi, UA/PL)
Апстрим	AS202425 IP Volume inc. (bulletproof)
Активен с	22 апреля 2026 (первые пульсы ОТХ)

1. Краткое заключение

Зафиксирована скоординированная ферма брутфорса, атакующая серверы MSSQL (TCP/1433) по всему миру. Инфраструктура состоит из 10 Windows VPS с единообразным профилем (RDP, SMB, WinRM, OpenSSH for Windows) и централизованной веб-панели управления на узле 194.113.39.2:8443. Панель использует самоподписанный TLS-сертификат с Subject O=MSSQL Panel — на момент анализа единственный экземпляр такого сертификата во всём интернете.

Оператор фермы — Vlad Cojuhari (Молдова/Украина), владелец AS205997 (zerolimit-servers.cool, зарегистрирован декабрь 2025). Подсеть анонсируется через AS206378 (FOP Dmytro Nedilskyi, Украина/Варшава), апстрим — AS202425 (IP Volume inc.), известный bulletproof-провайдер. Контакт abuse в RIPE: ban-me-please@zerolimit-servers.cool — намеренная демонстрация нежелания обрабатывать жалобы.

В соседней подсети 185.218.138.0/24 (тот же AS205997) обнаружено пять узлов с панелью "Ultimate RDP bruteforcer" на порту 9090. Тот же инструмент выявлен на двух внешних хостах: 80.66.66.68 (AS209702, Болгария) и 109.205.211.4 (AS201814 Mevspace, Польша) — вероятно, инструмент продаётся или передаётся сторонним операторам.

2. Инфраструктура

2.1. MSSQL-ферма — 194.113.39.0/24

Десять узлов с шагом адресов 4 (.2/.6/.10/.14/.18/.22/.26/.30/.34/.38). Все работают под Windows: OpenSSH for Windows, RDP (3389), SMB (445), WinRM (5985/47001), RPC (135). Узел .2 дополнительно несёт панель MSSQL на порту 8443.

IP	Открытые порты	Роль
194.113.39.2	22, 135, 445, 3389, 5985, 8443	Панель C2 + бот
194.113.39.6	22, 135, 445, 3389, 5985, 47001	Бот
194.113.39.10	22, 3389	Бот
194.113.39.14	22, 135, 139, 445, 3389, 5985	Бот
194.113.39.18	22, 135, 445, 3389, 5985	Бот
194.113.39.22	22, 135, 445, 3389, 5985	Бот
194.113.39.26	22, 135, 445, 3389, 5985	Бот
194.113.39.30	22, 3389	Бот
194.113.39.34	22, 135, 445, 3389, 5985	Бот
194.113.39.38	22, 135, 445, 3389, 5985	Бот

RDP на всех узлах: JARM 14d14d16d14d14d08c14d14d14d14dfd9c9d14e4f4f67f94f0359f8b28f532, JA3S ba1b42efc7dc57bb43bf81de59791c1b — типичный профиль Windows Server без членства в домене. SSH-ключи хостов уникальны для каждого узла (скриптовый деплой), HASSH 671c5858369db8e0a60108d866bbf8ec (дефолт OpenSSH for Windows — не уникальный индикатор).

2.2. Панель управления — 194.113.39.2:8443

Панель возвращает HTTP 401 Unauthorized с заголовком WWW-Authenticate: Basic realm="MSSQL Panel". Сертификат самоподписанный: Subject/Issuer O=MSSQL Panel, Serial=1, выпущен 2026-05-16 (развёрнут за 11 дней до анализа). HTTP-признаки (X-Content-Type-Options: nosniff, ECDSA P-256, TLS 1.3) указывают на Go-сервис собственной разработки.

Параметр	Значение
TLS SHA-256	fb3aa028387ecc371879ac10e123064050e766e6174fe4d1ddd1011db15e131a
TLS SHA-1	4b95c5c18abbc3b3b5885ab9576d7524d9e0f3b7
JARM	40d40d40d00000000043d43d00043d6aff5ab0f4fc31897186312c9e639319
JA3S	b210411e648f206db393c31561686aea
Дата выпуска	2026-05-16 13:52:36 UTC

Глобальный поиск в Shodan по ssl:"MSSQL Panel" возвращает ровно один результат — 194.113.39.2. Сертификат уникален для данной инфраструктуры. Тот же поиск по соседней подсети 185.218.138.0/24 того же оператора даёт ноль результатов: панель обслуживает только ферму 194.113.39.0/24.

2.3. RDP-брутфорсер — 185.218.138.0/24

Пять Windows-хостов в прямо владеемой AS205997 подсети запускают "Ultimate RDP bruteforcer" на порту 9090 (HTTP 200, заголовок Last-Modified: 2026-05-08). Хэш тела страницы (SHA-256: 9d7f1c8b83f2b1a0029e71a007220bdc2f3fdc66b7433464114045e6963309f7) обнаружен на 7 хостах по всему миру.

IP	ASN	Оператор	Страна
185.218.138.3	AS205997	Vlad Cojuhari	UA
185.218.138.5	AS205997	Vlad Cojuhari	UA
185.218.138.16	AS205997	Vlad Cojuhari	UA
185.218.138.17	AS205997	Vlad Cojuhari	UA
185.218.138.29	AS205997	Vlad Cojuhari	UA
80.66.66.68	AS209702	SOLDATOV-AS (Soldatov Alexey Valerevich)	BG
109.205.211.4	AS201814	Mevspace sp. z o.o.	PL

3. Атрибуция оператора

RIPE WHOIS для 194.113.39.0/24 (ORG-ZA297-RIPE): регистрант Vlad Cojuhari, Constantin Brancusi St 3, Молдова. Сеть создана 2026-01-30. IPinfo подтверждает: AS205997, website zerolimit-servers.cool, тип Hosting, ASN аллоцирован 2025-12-09.

AS206378 (STOLITOMSON-AS, FOP Dmytro Nedilskyi, Украина) анонсирует 194.113.39.0/24. Недилский также связан с AS211736 (31.43.160.0/19), фигурирующим в спам-блеклистах CleanTalk — характерная история анонса abuse-пространств.

Апстрим AS202425 (IP Volume inc.) — задокументированный bulletproof-провайдер, преемник Ecatel/Quasi Networks.

Домен zerolimit-servers.cool защищён CDN Cloudflare. Почтовая инфраструктура (mail.zerolimit-servers.cool) резолвится в 194.38.20.97 (AS48693 Rices, UA) — тот же AS, что напрямую пирится с AS205997. Почтовый сервер хостит множество посторонних доменов, характерных для shared-платформы спама или фишинга.

4. Сопоставление с MITRE ATT&CK

Тактика	Техника	ID	Свидетельство
Resource Development	Acquire Infrastructure: Server	T1583.003	10 bulletproof VPS в AS206378/AS205997
Resource Development	Acquire Infrastructure: Botnet	T1583.005	Скоординированная ферма + панель
Credential Access	Brute Force: Password Guessing	T1110.001	MSSQL (1433) brute-force по глобальным целям
Reconnaissance	Active Scanning: Scanning IP Blocks	T1595.001	OTX "Port Scanning Hosts" — все 10 узлов
Reconnaissance	Active Scanning: Service Scanning	T1595.002	Поиск открытых MSSQL 1433
Command and Control	Application Layer Protocol: Web	T1071.001	HTTPS-панель :8443, Basic-auth

5. Индикаторы компрометации

Тип	Значение	Контекст	Уверенность
IP	194.113.39.2	Панель C2 + бот	High
IP	194.113.39.6 / .10 / .14 / .18	MSSQL-боты	High
IP	194.113.39.22 / .26 / .30 / .34 / .38	MSSQL-боты	High
Подсеть	194.113.39.0/24	MSSQL-ферма (AS206378)	High
Подсеть	185.218.138.0/24	RDP-ферма + почта (AS205997)	Medium
TLS SHA256	fb3aa028387ecc371879ac10e123064050e766e6174fe4d1ddd1011db15e131a	Сертификат панели MSSQL	High

JARM	40d40d40d0000000043d43d00043d6aff5ab0f4fc31897186312c9e639319	Панель :8443	Medium
Домен	zerolimit-servers.cool	Бренд оператора / сайт ASN	High
IP	194.38.20.97	Origin почты zerolimit (AS48693)	Medium
ASN	AS205997 (Vlad Cojuhari)	Собственный ASN оператора	High
ASN	AS206378 (FOP Dmytro Nedilskyi)	Анонсирует 194.113.39.0/24	High
Email	ban-me-please@zerolimit-servers.cool	RIPE abuse-контакт (red flag)	High

6. Рекомендации

6.1. Немедленная блокировка

- Заблокировать 194.113.39.0/24 на периметре — особенно для входящих соединений к MSSQL/1433, RDP/3389 и SMB/445.
- Добавить 185.218.138.0/24 и 185.136.15.0/24 (тот же оператор, AS205997) в watchlist; блокировать проактивно при наличии открытых MSSQL/RDP.
- Мониторить или блокировать почту от zerolimit-servers.cool и 194.38.20.97.

6.2. Детект и охота

- Hunting по TLS: ssl.cert.subject.O="MSSQL Panel" в Shodan/Censys — для обнаружения новых экземпляров панели при смене IP оператором.
- Коррелировать новые /24-префиксы в AS205997 / AS206378 с Windows RDP JARM 14d14d16... и шагом адресов 4.
- MSSQL Event ID 18456 (Login failed) с source-IP из 194.113.39.0/24 — аномальный всплеск является надёжным индикатором активности фермы.

6.3. Долгосрочные меры

- Направить abuse-жалобы в RIPE против AS206378 и AS205997; эскалировать через апстрим AS202425 (IP Volume) — abuse-адрес zerolimit намеренно нефункционален.
- Отключить парольную аутентификацию MSSQL там, где это возможно; перейти на Windows-интегрированную или сертификатную аутентификацию.

TLP:CLEAR — Этот документ может распространяться без ограничений.